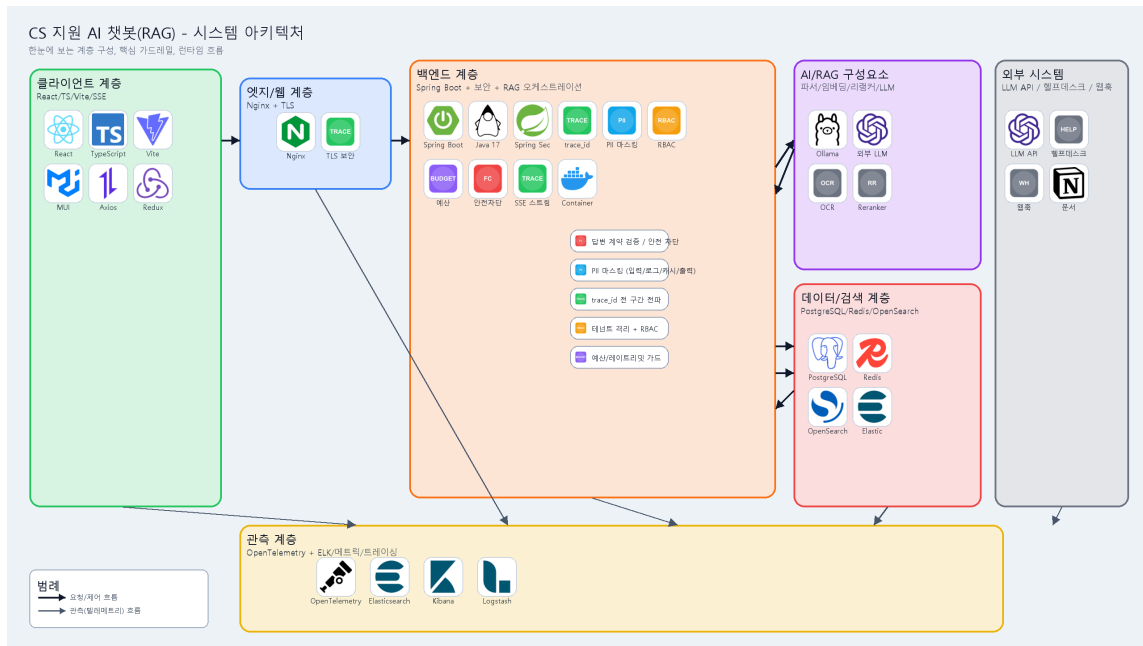


AI 챗봇 비개발자용 설계도

생성일: 2026-02-28 02:10 (local) | 출처: C:/Users/hjjmj/OneDrive/바탕
화면/AI_Chatbot/docs/reports/NON_DEV_PROJECT_BLUEPRINT.md

시스템 개요 다이어그램



AI 챗봇 비개발자용 설계도

기준일: 2026-02-27 (KST)

대상: 비개발자(기획/운영/상담/관리자)

1) 이 문서는 무엇을 설명하나요?

- 우리 프로젝트가 실제 업무에서 어떻게 동작하는지
- 큰 기능, 그 안의 하위 기능, 그리고 최소 단위 기능까지
- 시스템이 "위험한 답변"을 어떻게 막는지
- 문제가 생겼을 때 사용자가 무엇을 보게 되는지

2) 한눈에 보는 전체 흐름 (상담원 질문 1건 기준)

1. 상담원이 로그인한다.
2. 시스템이 사용자 권한(ROLE)과 소속 테넌트를 확인한다.
3. 상담 세션을 만든다.

4. 상담원이 질문을 보낸다.
5. 시스템이 관련 근거 문서(RAG)를 먼저 찾는다.
6. AI가 근거를 바탕으로 "구조화된 답변 초안"을 만든다.
7. 안전 검증(Answer Contract, 근거/정책/형식 검증)을 수행한다.
8. 통과하면 스트리밍으로 답변 + 근거를 화면에 보여준다.
9. 실패하면 자유 답변 대신 safe_response(안전 안내문)만 보여준다.
10. 모든 과정은 trace_id로 추적되어 운영자가 사후 확인할 수 있다.

3) 기능 계층도 (큰 기능 -> 하위 기능 -> 최소 단위)

A. 상담 업무 기능

- A1. 상담 시작
 - A1-1. 로그인
 - A1-2. 초기 정보 불러오기(권한, 환경, UI 기초 데이터)
 - A1-3. 세션 생성
- A2. 질문/답변
 - A2-1. 질문 전송
 - A2-2. 답변 스트리밍 수신
 - A2-3. 응답 재개(resume)
 - A2-4. 근거(citation) 패널 확인
- A3. 상담 마무리
 - A3-1. 세션 단위 히스토리 확인
 - A3-2. 오류 코드/안전응답 확인

B. AI 답변 품질/안전 기능

- B1. 근거 기반 생성(RAG)
 - B1-1. 관련 문서 검색
 - B1-2. 상위 근거(top_k) 선택
 - B1-3. 근거와 함께 답변 초안 생성
- B2. Answer Contract
 - B2-1. JSON 구조 검증
 - B2-2. citation 존재 검증
 - B2-3. evidence 임계치 검증
 - B2-4. 정책 문구(금지/필수) 검증

- B3. Fail-Closed
 - B3-1. 검증 실패 시 자유 텍스트 차단
 - B3-2. safe_response 이벤트 송신
 - B3-3. done 이벤트로 스트림 종료

C. 보안/권한/격리 기능

- C1. 인증/권한(RBAC)
 - C1-1. JWT 인증 확인
 - C1-2. ROLE 검증(AGENT/CUSTOMER/ADMIN/OPS/SYSTEM)
 - C1-3. 미권한 요청 403 차단
- C2. 테넌트 격리
 - C2-1. X-Tenant-Key 필수 확인
 - C2-2. 데이터 조회/저장 시 테넌트 경계 유지
 - C2-3. 타 테넌트 접근 차단
- C3. 개인정보(PII) 보호
 - C3-1. 모델 입력 전 마스킹
 - C3-2. 로그 저장 전 마스킹
 - C3-3. 응답/증거 화면 노출 시 마스킹

D. 운영 안정성 기능

- D1. 추적성(Observability)
 - D1-1. trace_id 발급/전파
 - D1-2. 요청 -> 검색 -> 모델 -> 응답 구간 로그 연결
 - D1-3. 장애 원인 추적
- D2. 예산/오남용 방어
 - D2-1. 토큰 사용량 제한
 - D2-2. tool 호출 횟수 제한
 - D2-3. SSE 동시 연결 제한
 - D2-4. 초과 시 429/403 반환
- D3. 장애 대응
 - D3-1. safe_response로 안전 실패
 - D3-2. 표준 오류 payload 반환(error_code, message, trace_id, details)
 - D3-3. 운영 Runbook 기준 대응

4) 비개발자가 이해하면 좋은 "체크포인트"

- 답변이 보여도 반드시 근거(citation)가 같이 보여야 정상이다.
- 근거가 없거나 정책 위반이면 "답변을 못하는 것"이 정상 동작이다.
- 오류가 나도 trace_id가 있으면 운영팀이 빠르게 추적 가능하다.
- 권한/테넌트가 다르면 같은 질문이라도 접근 가능한 정보가 달라진다.

5) 자주 보는 에러/안전 코드 예시

- SEC-001-401: 인증 실패
- SEC-002-403: 권한 없음/접근 금지
- API-008-429-BUDGET: 예산 초과
- API-008-429-SSE: SSE 동시 연결 초과
- AI-009-200-SAFE: fail-closed에 따른 안전 응답

6) 현 시점 기준 핵심 메시지

- 이 시스템의 핵심 목적은 "빨리 답하는 것"이 아니라 "근거 있고 안전하게 답하는 것"이다.
- 안전 기준을 충족하지 못하면 답변을 멈추는 것이 의도된 정상 동작이다.
- 운영 관점에서는 trace_id, 에러코드, 근거 패널 3가지만 확인해도 1차 진단이 가능하다.

참고 문서

- docs/architecture/NOTION_System_Architecture.md
- docs/review/mvp_verification_pack/01_MVP_EXPLAIN_FOR_NON_DEV.md
- docs/review/mvp_verification_pack/CURRENT.md